

versione realisticamente svolgibile da uno studente in una seconda prova di Sistemi e Reti.

Caratteristiche:

- coerente con una prova d'esame da 6 ore;
- sufficientemente dettagliata;
- senza eccessiva complessità "enterprise";
- con spiegazioni sintetiche
- con diagrammi semplici e realistici.

## Sistemi e Reti - Sessione straordinaria 2024

### Versione Studente

Esempio di soluzione realistica svolgibile da uno studente

### PRIMA PARTE

#### 1. Analisi del problema

L'azienda apre una nuova sede in una città diversa dalla sede centrale.

Nella nuova sede sono presenti:

- reparti di sviluppo software A, B e C;
- reparto D per test qualità;
- reparto E per project management;
- reparto F per amministrazione.

I reparti A, B e C devono essere separati tra loro.

Il reparto D deve poter accedere ai file server dei reparti A/B/C per effettuare i test.

Il reparto E deve poter accedere ai file server e trasferire le versioni finali verso il repository centrale.

Il reparto F deve accedere a Internet e al gestionale remoto della sede centrale.

La rete deve essere sicura, scalabile e facilmente gestibile.

#### 2. Scelte progettuali

Si sceglie una rete:

- Ethernet Gigabit per le postazioni;
- VLAN separate per ogni reparto;
- switch Layer 3 centrale per il routing tra VLAN;
- firewall/NGFW per accesso Internet e VPN;
- autenticazione centralizzata tramite Active Directory;
- VPN IPsec site-to-site verso la sede centrale.

Per motivi di sicurezza:

- i reparti A/B/C non possono comunicare tra loro;
- il reparto D può accedere solo ai file server;
- il reparto E può accedere ai file server e al repository centrale;
- la rete ospiti è separata.

#### 3. Dimensionamento postazioni

| Reparto | PC previsti | Riserva 10% | Totale |
|---------|-------------|-------------|--------|
| A       | 50          | 5           | 55     |
| B       | 30          | 3           | 33     |
| C       | 100         | 10          | 110    |
| D       | 20          | 2           | 22     |
| E       | 10          | 1           | 11     |

| Reparto | PC previsti | Riserva 10% | Totale |
|---------|-------------|-------------|--------|
| F       | 20          | 2           | 22     |

## 4. Architettura generale

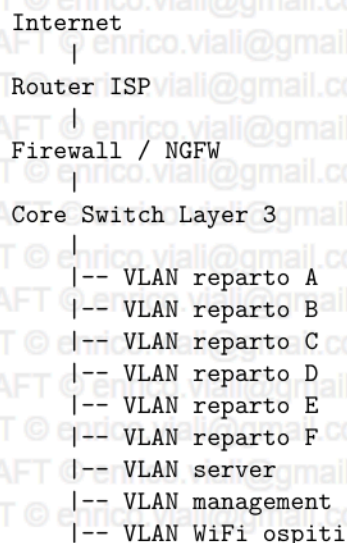
La rete usa una struttura a due livelli:

- switch di accesso per i reparti;
- core switch Layer 3 centrale.

Il firewall è posto tra LAN aziendale e Internet.

La VPN collega la nuova sede con la sede centrale.

Schema:



## 5. Piano di indirizzamento

Rete scelta: 10.24.0.0/16

| VLAN | Reparto          | Subnet        | Gateway    |
|------|------------------|---------------|------------|
| 10   | Reparto A        | 10.24.10.0/26 | 10.24.10.1 |
| 20   | Reparto B        | 10.24.20.0/26 | 10.24.20.1 |
| 30   | Reparto C        | 10.24.30.0/25 | 10.24.30.1 |
| 40   | Reparto D        | 10.24.40.0/27 | 10.24.40.1 |
| 50   | Reparto E        | 10.24.50.0/28 | 10.24.50.1 |
| 60   | Reparto F        | 10.24.60.0/27 | 10.24.60.1 |
| 70   | Server e servizi | 10.24.70.0/27 | 10.24.70.1 |
| 80   | Management       | 10.24.80.0/28 | 10.24.80.1 |
| 90   | WiFi ospiti      | 10.24.90.0/24 | 10.24.90.1 |

Esempio:

- VLAN 10 usa subnet /26;
- gateway: 10.24.10.1;
- primo IP disponibile per client: 10.24.10.2;
- broadcast: 10.24.10.63.

## 6. Principali server e servizi



| Sistema       | IP          |
|---------------|-------------|
| File server A | 10.24.70.10 |
| File server B | 10.24.70.11 |
| File server C | 10.24.70.12 |
| AD/LDAP       | 10.24.70.20 |
| DNS           | 10.24.70.21 |
| DHCP          | 10.24.70.22 |
| RADIUS        | 10.24.70.23 |

Servizi principali:

- autenticazione centralizzata;
- DNS interno;
- DHCP;
- file sharing SMB/CIFS;
- VPN IPsec;
- backup.

## 7. Regole di comunicazione

| Sorgente    | Destinazione        | Accesso                |
|-------------|---------------------|------------------------|
| Reparto A   | File server A       | consentito             |
| Reparto A   | Reparto B/C         | negato                 |
| Reparto D   | File server A/B/C   | consentito             |
| Reparto E   | File server A/B/C   | consentito             |
| Reparto E   | Repository centrale | consentito tramite VPN |
| Reparto F   | Gestionale centrale | consentito tramite VPN |
| WiFi ospiti | LAN interna         | negato                 |

La regola generale è deny by default.

## 8. Sicurezza

Misure di sicurezza adottate:

- VLAN separate;
- ACL sullo switch Layer 3;
- firewall/NGFW;
- VPN IPsec;
- autenticazione utenti;
- password complesse;
- backup;
- antivirus/EDR;
- logging;
- aggiornamenti software.

Per il WiFi aziendale si usa WPA2-Enterprise oppure WPA3-Enterprise con autenticazione RADIUS.

## 9. Collegamento con sede centrale

Il collegamento avviene tramite VPN IPsec site-to-site tra i firewall delle due sedi.

Schema:

Nuova sede

|

Firewall VPN

|

Tunnel IPsec cifrato

|

Firewall sede centrale

|

Repository e gestionale

Il traffico sulla VPN è limitato ai servizi necessari.

---

## 10. Configurazione di un servizio

Esempio: file server reparto A.

Nome server: FS-A

IP: 10.24.70.10

Cartelle:

\\FS-A\progetti\_A

  \In\_Lavorazione

  \In\_Test

  \Finali

Permessi:

- DEV\_A: lettura/scrittura;
- TEST\_QA: scrittura report e chiusura progetto;
- PROJECT\_MANAGER: lettura e rilascio;
- IT\_ADMIN: controllo completo.

Quando un progetto supera i test:

- il reparto D aggiunge il suffisso \_Final\_Version;
  - la cartella viene resa read-only;
  - il reparto E pubblica la versione finale sul repository centrale.
- 

## SECONDA PARTE

### Quesito I

I server pubblici della sede centrale devono essere posti in DMZ.

Schema:

Internet

|

Firewall

|

-- DMZ

|

  |-- Web server e-commerce

|

  |-- Mail gateway

|

-- LAN interna

|

  |-- Repository

|

  |-- Gestionale

|

  |-- Database

Il database non deve essere esposto direttamente su Internet.

Servizi pubblici:

- HTTPS 443;
  - SMTP 25;
  - SMTP submission 587;
  - IMAPS 993.
-



## Quesito II

La virtualizzazione permette di usare un unico server fisico con più macchine virtuali.

Vantaggi:

- minore costo hardware;
- migliore utilizzo delle risorse;
- backup e gestione più semplici.

Le VM rimangono separate tramite VLAN.

Differenza tra hypervisor:

- tipo 1: installato direttamente sull'hardware;
- tipo 2: installato sopra un sistema operativo.

---

## Quesito III

WEP:

- vecchio e insicuro.

WPA:

- miglioramento di WEP;
- oggi superato.

WPA2:

- molto diffuso;
- WPA2-Enterprise usa autenticazione RADIUS.

WPA3:

- standard più moderno e sicuro.

Per l'azienda è consigliato WPA2-Enterprise oppure WPA3-Enterprise.

---

## Quesito IV

Il firewall controlla il traffico tra reti.

Tipi principali:

- packet filtering;
- stateful firewall;
- NGFW.

Il proxy controlla il traffico applicativo HTTP/HTTPS.

Il reverse proxy riceve richieste esterne e le inoltra ai server.

Il WAF protegge le applicazioni web contro attacchi come SQL injection e XSS.

Nel nostro caso:

- firewall per Internet e VPN;
- ACL per separazione reparti;
- WAF per il sito e-commerce.

---

## Punti Specifici

### Server di reparto

Nella soluzione semplificata che uno studente può realisticamente svolgere, la situazione può risultare ambigua perché:

- viene citata una "VLAN server";
- ma contemporaneamente i file server sembrano associati ai singoli reparti.

Conviene chiarire esplicitamente i due possibili approcci.

## Soluzione più semplice e più adatta all'esame

In una soluzione d'esame semplice e molto comprensibile:

- ogni reparto ha UNA sola VLAN;
- nella stessa VLAN stanno:
  - PC del reparto;
  - file server del reparto;
  - stampante del reparto.

Quindi:

| VLAN    | Contenuto                          |
|---------|------------------------------------|
| VLAN 10 | PC A + File Server A + Stampante A |
| VLAN 20 | PC B + File Server B + Stampante B |
| VLAN 30 | PC C + File Server C + Stampante C |

Questa soluzione è:

- semplice;
- non totalmente coerente con la traccia e l'orientamento attuale alla sicurezza ma accettabile;
- facile da spiegare;

In questo caso NON serve una VLAN server separata per A/B/C.

La VLAN "Server e servizi" può allora contenere solo:

- Active Directory / LDAP;
- DNS;
- DHCP;
- RADIUS;
- logging;
- eventuali servizi infrastrutturali comuni.

Quindi:

| VLAN 70   | Servizi infrastrutturali comuni |
|-----------|---------------------------------|
| Contenuto | AD, DNS, DHCP, RADIUS, logging  |

## Soluzione più professionale

In una soluzione non semplificata utenti e server vengono separati.

Esempio:

| VLAN    | Contenuto                   |
|---------|-----------------------------|
| VLAN 10 | utenti reparto A            |
| VLAN 11 | file server A + stampante A |
| VLAN 20 | utenti reparto B            |
| VLAN 21 | file server B + stampante B |

Questo approccio è tecnicamente migliore e scelta primaria in ambito professionale perché:

- permette ACL più "precise";
- isola i server;
- migliora sicurezza e logging.

Ma aumenta:

- complessità;
- numero VLAN;
- configurazioni ACL.



## Quale conviene usare all'esame?

E' preferibile:

- soluzione semplice se il tempo è limitato o non si è ferratissimi;
- soluzione avanzata se si ha tempo e si riesce a gestirla bene.

Molti errori nascono proprio dal voler complicare troppo la soluzione.

Se si sceglie la soluzione semplice questo va esplicitamente e chiaramente specificato, molte tracce richiedono di specificare le assunzioni, anche se la traccia non lo richiede va comunque e sempre specificato, questa e qualunque altra assunzione.

Un esempio potrebbe essere:

per i file server e le stampanti dei reparti A/B/C avere reti dedicate sarebbe desiderabile e allineato all'attuale orientamento alla sicurezza, ma file server e stampanti sono collocati nella stessa VLAN del relativo reparto per semplificare la progettazione della rete

Nella versione avanzata è meno necessario spiegare dato che stiamo scegliendo la soluzione tecnicamente ottimale, è comunque sempre positivo spiegare le scelte, un esempio potrebbe essere:

I file server e le stampanti vengono separati dagli utenti del loro reparto e posti in VLAN dedicate per migliorare l'isolamento e quindi migliorare la sicurezza

### Accesso a file server di altri reparti

La traccia richiede esplicitamente che:

- il reparto D acceda ai file server A/B/C;
- il reparto E (Project Management) acceda ai file server A/B/C.

Quindi la situazione è:

- isolamento di default;
- eccezioni controllate tramite ACL e permessi applicativi.

## Come funziona realmente

Occorre distinguere due livelli:

| Livello                  | Funzione                               |
|--------------------------|----------------------------------------|
| Rete (VLAN + ACL)        | decidere chi può raggiungere il server |
| Applicazione/File server | decidere cosa può fare l'utente        |

### Primo livello: ACL di rete

Le ACL permettono SOLO i flussi necessari.

Esempio:

| Sorgente | Destinazione      | Consentito |
|----------|-------------------|------------|
| VLAN A   | File Server A     | sì         |
| VLAN A   | File Server B     | no         |
| VLAN D   | File Server A/B/C | sì         |
| VLAN E   | File Server A/B/C | sì         |

Quindi:

- i tester possono raggiungere i file server;
- i project manager possono raggiungerli;
- gli sviluppatori degli altri reparti no.

## Secondo livello: permessi sul file server

Anche se la rete consente la connessione ovviamente **non tutti possono fare tutto** (least privilege).

I permessi dipendono:

- dall'utente autenticato;
- dai gruppi AD/LDAP;
- dalle ACL filesystem.

Esempio sul File Server A:

| Gruppo          | Permessi                      |
|-----------------|-------------------------------|
| DEV_A           | lettura/scrittura             |
| DEV_B           | nessun accesso                |
| DEV_C           | nessun accesso                |
| TEST_QA         | accesso controllato aree test |
| PROJECT_MANAGER | lettura/versioni finali       |
| IT_ADMIN        | controllo completo            |

In termini pratici abbiamo due “livelli”

### Livello rete

Decide:

“questa VLAN può raggiungere questo server?”

### Livello file system

Decide:

“questo utente può leggere/modificare questa cartella?”

## Esempio

### Caso: tester reparto D

1. PC reparto D in VLAN 40
2. ACL permette:  
VLAN40 -> FileServerA SMB 445
3. Tester si autentica con account aziendale
4. File server verifica gruppi AD
5. Tester può:
  - leggere area test;
  - scrivere report;
  - rinominare progetto finale.

Ma NON può:

- cancellare cartelle amministrative;
- accedere ad altri dati non autorizzati.

### Caso: Project Manager

Il PM:

- raggiunge i file server;
- legge versioni finali;
- pubblica sul repository centrale.

Ma normalmente:



- non modifica codice in lavorazione;
- non ha privilegi amministrativi completi.

## **Precisazione**

Ingenuamente, ed erroneamente, si potrebbe pensare:

“ACL = sicurezza completa”

In realtà no.

Le ACL:

- controllano il traffico di rete;
- **NON** sostituiscono i **permessi applicativi**.

Una rete professionale usa entrambi:

- segmentazione di rete;
- autenticazione;
- autorizzazioni applicative.